TEK306- Week 38 quiz- solution

Main Objectives

The main objective of this exercise is to be able to describe Threat modeling in the context of mobile applications, REST APIs and secure REST-based communications.

Description of the Assignment

Attempt each of the below questions as they appear and complete them, preferably as classwork (if you get the time) or later as homework 😊

(1) State the benefits of "threat modeling" in a project.

Answer: Threat modeling should be part of the development process. For example, Microsoft, which has developed the STRIDE threat modeling tool, has threat modeling as a central part of its Security Development Lifecycle (SDL) process.

"Applying a structured approach to threat scenarios during design helps a team more effectively and less expensively identify security vulnerabilities, determine risks from those threats, and establish appropriate mitigations." – Microsoft SDL documentation

Therefore, the threat model is an excellent aid in achieving a better and more secure system design, and it is also an essential input for the security testing process.

(2) Consider the scenario shown in the below figure. The system consists of health data (heart rate and breath rate) monitoring smartwatch that communicates with a mobile phone using Bluetooth. The mobile phone is also connected to a cloud-based health information storage (i.e., stores the readings pushed by the smartwatch) via an App. The App uses a web interface, and the App does not know or care if the connection uses WiFi or a cellular data link. With respect to the given scenario, identify a threat

for each of the threat categories in STRIDE (spoofing, tampering, repudiation, information disclosure, denial of service, elevation of privilege) and propose suitable countermeasures to address each of the identified threats.

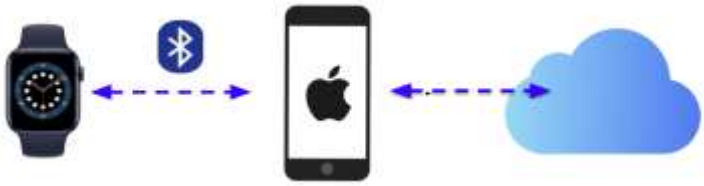


Figure: Threat modeling scenario.

Answer:

STRIDE threats:

1. Smartwatch (Boundary A)

1.1. Spoofing: the smartwatch may be spoofed (false smartwatch identifier)

1.2. Tampering: Falsifying data

1.3. Repudiation: Denial of consumed data, produced data

1.4. Information disclosure: Leaking health data

1.5. Denial of Service: Disabling some function of the smartwatch

1.6. Elevation of Privilege: It seems complicated to see how this can be done.

2. Bluetooth

2.1. Spoofing: smartwatch and/or smartphone may be impersonated

2.2. Tampering: Falsifying data

2.3. Repudiation: Denial of consumed data, produced data

2.4. Information disclosure: Leaking health data

2.5. Denial of Service: Disrupt communications

2.6. Elevation of Privilege: It seems complicated to see how this can be done.

3. Smartphone (Boundary B)

3.1. Spoofing: smartphone may be impersonated

3.2. Tampering: Falsifying data

3.3. Repudiation: Denial of consumed data, produced data

3.4. Information disclosure: Leaking health data, subscription data

3.5. Denial of Service: Disrupt communications/service

3.6. Elevation of Privilege: It seems complicated to see how this can be done.

4. HTTP

4.1. Spoofing: smartphone/cloud server may be impersonated

4.2. Tampering: Falsifying data

4.3. Repudiation: Denial of consumed data, produced data

4.4. Information disclosure: Leaking health data, subscription data

4.5. Denial of Service: Disrupt communications/service

4.6. Elevation of Privilege: It seems complicated to see how this can be done.

5. Cloud Server (Boundary C)

5.1. Spoofing: cloud server may be impersonated

5.2. Tampering: Falsifying data

5.3. Repudiation: Denial of consumed data, produced data

5.4. Information disclosure: Leaking health data, subscription data

5.5. Denial of Service: Disrupt communications/service

5.6. Elevation of Privilege: It seems complicated to see how this can be done.

To address the threats:

- Harden the cloud service

- Harden the smartphone app

- Harden the smartwatch

- Full Bluetooth security (data confidentiality, data integrity, and authentication)

- Use TLS for HTTP connection- If one-way TLS, then ensure that App is fully

authenticated (password)

(3) What is a REST interface?

Answer: REST interfaces provide Web services by using Web protocols such as HTTP. They have features like scalability, maintainability, help multiple application communication built on various programming languages, etc.

REST-based Web service implementation defines the method of accessing various resources that are required by the client.

(4) List the features of REST-based Web services.

Answer: Every REST-based service has the following features:

- It works based on the client-server communication model.
- Commonly uses the HTTP protocol for performing functions like retrieving resources from the web server, execution of any query, etc.
- The client-server communication is performed through 'messaging'.
- Resources available on the server are addressed through URIs.
- It is stateless in that every client-server request-response is independent of each other with complete assurance of providing required information.
- It works based on the uniform interface (HTTP verbs).
- It uses the concept of caching.

(5) Describe a Web resource in the context of the REST interface.

Answer: A web resource can be any data object of type image, HTML file, text data, and video. There are varieties of resource representation formats and some most common ones are- JSON, YAML, XML, and HTML.

https://www.softwaretestinghelp.com/restful-web-services-interview-question/

(6) Explain how the OAuth 2.0 works?

Answer: OAuth 2.0 is used for the authorization of secure access to protected data stored on a server, and the request workflow is performed as the below:

- When a user attempts to access a resource on a secure server, the user's application initiates the OAuth 2.0 authorization process.
- The request is directed to the authorization server with a scope specifying actions to retrieve, insert, update, or delete when authenticated.
- The authorization server returns an access token to the client application to access those resources.

(7) What is the Internet of Things? Explain the role of mobile applications in IoT.

Answer: IoT is a system of internet-connected objects that collect and transfer data over a wired as well as wireless network and brings endless possibilities without human intervention. It collects data through sensors to the cloud, processes it and then decide to perform an action. Mobile applications play a significant role and used as an interface for users to interact with IoT-enabled physical devices.

References:

- https://simpleprogrammer.com/oauth-and-rest-in-android-part-1/
- https://en.wikipedia.org/wiki/Representational_state_transfer